ONE-PAGE BRIEF

Post-quantum cryptography review: scroll @ 3046bbd18a6a

Client: Scroll — public repository (passive review) · Source: github.com/scroll-tech/scroll, commit `3046bbd18a6a` · Reviewed: 2026-10-29 06:18 UTC · Risk profile: Web3 project

POST-QUANTUM MATURITY
Level 0 of 4
no post-quantum cryptography

FINDINGS
1 Critical **9** High **13** Medium
35 Low **57** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)
Signatures: 10 + 5 − 12 = 3 → **too late**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

Critical QSI-2026-06635	**github.com/gin-contrib/cors v1.5.0 is affected by GHSA-869c-j7wc-8jqv (CVE-2019-25211, GO-2024-2955)** What to do: Upgrade to a fixed version (1.6.0).
High QSI-2026-06538	**TLS certificate verification disabled in bridge-history-api/cmd/api/app/app.go** What to do: Remove the override; use a proper CA bundle or pinning.
High QSI-2026-06636	**github.com/btcsuite/btcd v0.20.1-beta is affected by GHSA-27vh-h6mc-q6g8 (CVE-2024-38365...** What to do: Upgrade to a fixed version (0.24.2-beta.rc1).
High QSI-2026-06547	**Possible reentrancy (external call before state update) in...** preliminary What to do: Apply checks-effects-interactions and/or ReentrancyGuard.

54 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium transaction and message signing	ECDSA	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum...
Medium authentication and identity (certificates, tokens, device attestation)	ECDSA	Keep credentials short-lived and plan ML-DSA certificates, tokens and keys as the ecosystem supports them
Medium role not determined	ECDSA	Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205)...

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 57; unlikely to apply to this build: 29 (a Cargo feature that is off, affected functions not named in the code, or a platform that is not built); to review: 28.

Static review of source code and manifests; files analysed: 387. No requests were sent to the owner's systems.

Full report, content SHA-256: `bfe57c31bc57c669da6e4a7cee997a8bd19fd26d0a62a5decfc2255b7452d9bb`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.